
CAPACITAÇÃO EM DESENVOLVIMENTO WEB 3.0

Gustavo Davyd de Oliveira Mota

ATIVIDADE - III

FORTALEZA - CE - 08 / 03 / 2026



1 Relatório de Auditoria de Smart Contracts

1.1 Objetivo da auditoria

Avaliar a segurança dos *smart contracts* desenvolvidos no MVP, identificar possíveis vulnerabilidades, classificar riscos e registrar as mitigações implementadas.

1.2 Escopo avaliado

Contratos auditados:

- `contracts/GovernanceToken.sol`
- `contracts/ProtocolNFT.sol`
- `contracts/Staking.sol`
- `contracts/SimpleGovernance.sol`
- `contracts/interfaces/AggregatorV3Interface.sol`

Arquivos de suporte relevantes:

- `hardhat.config.js`
- `test/Protocol.test.js`
- `scripts/deploy.js`

1.3 Metodologia

A auditoria foi realizada em três frentes:

1. **Análise estática (Slither):** busca de padrões inseguros, problemas de lógica, centralização e riscos de *design*.
2. **Análise simbólica (Mythril):** execução simbólica para investigar cenários de exploração e fluxos críticos.
3. **Validação funcional (Hardhat):** execução de testes automatizados e cenários de uso para confirmar comportamento esperado.



1.4 Ferramentas utilizadas

- **Hardhat** (compilação e testes)
- **Slither** (análise estática)
- **Mythril** (análise simbólica)

Comandos utilizados:

- `npx hardhat compile`
- `npx hardhat test`
- `slither .`
- `docker run -v "%cd%:/share" mythril/myth analyze /share/contracts/StakingToken.sol`

1.5 Resumo dos resultados

Resultado geral da auditoria:

- **Crítico:** 0
- **Alto:** 0
- **Médio:** 0
- **Baixo:** 0
- **Informativo/Design:** 3

O projeto não apresentou vulnerabilidades críticas conhecidas nos fluxos auditados.

1.6 Achados da auditoria

1.6.1 A-01 - Centralização por funções administrativas

- **Severidade:** Informativo
- **Contrato:** `Staking.sol`, `GovernanceToken.sol`
- **Descrição:** parâmetros e funções administrativas dependem de `owner`, incluindo ajuste de recompensa e mint administrativo.



-
- **Impacto:** risco de governança/operacional em caso de comprometimento de chave administrativa.
 - **Mitigação aplicada:** controle de acesso explícito com `Ownable` e separação de papéis no fluxo.
 - **Recomendação futura:** migrar administração para *multisig/timelock*.

1.6.2 A-02 - Governança simplificada sem timelock

- **Severidade:** Informativo
- **Contrato:** `SimpleGovernance.sol`
- **Descrição:** propostas aprovadas podem ser executadas sem camada de *timelock* adicional.
- **Impacto:** menor janela de reação para participantes em caso de proposta maliciosa aprovada.
- **Mitigação aplicada:** período de votação por blocos e *snapshot* de votos com `ERC20Votes`.
- **Recomendação futura:** adicionar *timelock* e quórum mínimo.

1.6.3 A-03 - Dependência de oráculo externo

- **Severidade:** Informativo
- **Contrato:** `Staking.sol`
- **Descrição:** taxa de recompensa depende do *feed* Chainlink ETH/USD.
- **Impacto:** disponibilidade/consistência do *feed* impacta a dinâmica econômica.
- **Mitigação aplicada:** uso de *feed* oficial Chainlink e validação básica de preço positivo.
- **Recomendação futura:** incluir proteção contra dados *stale* e *circuit breaker* para falhas do oráculo.

1.7 Controles de segurança implementados

- Uso de **OpenZeppelin** em padrões ERC.
- Uso de **Solidity** ^0.8.x (checks nativos contra overflow).
- Proteção de reentrância com `ReentrancyGuard`.



-
- Transferências seguras com `SafeERC20`.
 - Controle de acesso com `Ownable`.
 - *Snapshot* de votos com `ERC20Votes` para reduzir manipulação por transferência após criação da proposta.

1.8 Testes executados

Testes automatizados com Hardhat cobriram:

1. *Stake* e resgate de recompensas;
2. Criação de proposta;
3. Votação na DAO;
4. Execução de proposta para *mint* de NFT.

Os testes passaram com sucesso no ambiente local.

1.9 Risco residual

Mesmo sem achados críticos, permanecem riscos típicos de MVP:

- Dependência de chave administrativa (`owner`);
- Ausência de *timelock*/quórum avançado na governança;
- Dependência de disponibilidade do oráculo externo.

Esses pontos são esperados no escopo simplificado da atividade e podem ser evoluídos em versões futuras.

1.10 Conclusão da auditoria

O protocolo foi considerado **apto para demonstração em testnet**, com arquitetura coerente, controles básicos adequados ao escopo acadêmico e ausência de vulnerabilidades críticas identificadas nas verificações aplicadas.

As recomendações para evolução incluem:

- Adoção de *multisig* para administração;



-
- Inclusão de *timelock* e quórum robusto na governança;
 - Validações adicionais para robustez do oráculo.

